

ARTIFICIAL INTELLIGENCE GOVERNANCE POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Artificial Intelligence Governance Policy
Document ID	POL-AI-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC1.1, CC3.4, CC6.1, CC6.7, CC7.2, CC7.3, CC8.1 and CC9.2, and GDPR Articles 5, 6, 28 and 32. It governs how the Company builds with and uses AI; it does not restate controls owned by other documents.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 RELATIONSHIP TO THE OTHER POLICIES6

6 HOW MUCH SCRUTINY A USE ATTRACTS7

7 THE APPROVED AI TOOL REGISTER.....7

8 USING AI ASSISTANTS.....7

9 MODEL PROVIDERS8

10 AGENTS AND AUTOMATION.....8

11 PROMPTS, MODELS AND CONFIGURATION.....8

12 THE CHECK BEFORE SHIPPING.....9

13 KEEPING UP WITH THE FIELD9

14 RECORDS9

15 ENFORCEMENT..... 10

16 EXCEPTIONS..... 10

17 REFERENCE..... 10

1 DOCUMENT POLICY HISTORY 10

1 Overview and Purpose

PromptHalo Technologies (“the Company”) builds with AI and uses AI in ordinary work. This Policy governs both: which tools may be used and on what data, how models and agents are changed, what is checked before a change is deployed, and who remains accountable for what an AI system produces.

The Company is a small, remote team working in AWS, Google Workspace, GitHub and approved AI services, mostly from personally owned laptops. This Policy is written so that using AI well is the easy path and using it badly is the one that requires a deliberate departure.

2 Scope

This Policy applies to every use of AI for Company or client work: assistants used by personnel, models and inference services the Company builds on, agents that act on systems, and retrieval over Company or client data.

It does not extend to a person's private use of AI on their own device with no Company or client information involved.

This Policy is written to be the easy path: two rules carry nearly all the risk — keep client data out of unapproved tools, and do not let software act on its own authority. Everything else is proportionate to what the use touches, and where a requirement here would slow legitimate work without reducing risk, it is not in this Policy.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party maintains the approved AI tool register, decides whether a proposed tool or model may be used and on what classification of data, and records the AI-specific external change review. [SOC 2: CC9.2, CC3.4]
5. Every agent and every automated workflow have a named owner. A named person remains accountable for any AI output the Company relies on; accountability is not transferred to a model. [SOC 2: CC1.1, CC1.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.

2. **Agent** — software that takes actions on Company or client systems using tools or interfaces, rather than only producing text for a person to read.
3. **Approved AI tool** — an AI service on the register at Section 7, reached through a Company account under the terms assessed for it.
4. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
5. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
7. **Evaluation** — the check performed before an AI change is deployed, described at Section 12.
8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
9. **Model provider** — a third party supplying a model or inference service, assessed as a vendor and usually a sub-processor.
10. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
11. **Prompt** — the instruction set given to a model, including system prompts, tool definitions and retrieval configuration.
12. **Security Officer** — the individual accountable for day-to-day operation of the security program.
13. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
14. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Relationship to the Other Policies

This Policy states what is specific to AI. Where a requirement already exists elsewhere, this Policy points at it and does not repeat it — a duplicated requirement is one that will be amended in one place and left stale in the other.

1. Change approval, review and deployment for prompts, tool definitions, retrieval configuration, guardrails and model versions follows the Change Management Policy, on the same path as code. This Policy adds only the evaluation at Section 12, which is an additional check and not a separate approval route. [SOC 2: CC8.1]

2. Logging of agent and model activity follows the Logging and Monitoring Policy and the Logging Standard. This Policy states what must be reconstructable; those documents state how it is recorded, retained and reviewed. [SOC 2: CC7.2]
3. Model providers are assessed under the Vendor Management Policy. Identities and access for agents follow the Access Control Policy. Incidents follow the Incident Response Policy. Personal use rules for personnel are in the Acceptable Use Policy. [SOC 2: CC9.2, CC6.1, CC7.3, CC1.1]

6 How Much Scrutiny a Use Attracts

Two questions decide it: does it touch client information, and can it act rather than advise.

1. Using AI — a person prompts a tool and reads the result. Use an approved tool through a Company account and observe the data rules at Section 8. Nothing further is required, and most use here is this. [SOC 2: CC6.7]
2. Shipping AI — a model sits in the path of something the Company delivers, or software acts on systems. This attracts the change handling at Section 11, the check at Section 12, and for anything that acts, the limits at Section 10. [SOC 2: CC8.1, CC6.1]
3. A use that crosses from the first into the second — an assistant given tools, a prototype put in front of a client — is reassessed before it does. That reassessment is the point of control, not a standing approval process. [SOC 2: CC3.4, CC8.1]

7 The Approved AI Tool Register

One list, four columns, kept in a sheet. It exists so that people know what they may use without asking each time.

1. For each tool: the provider, the account tier in use, the highest data classification permitted, and the date last looked at. That is the whole record. [SOC 2: CC9.2, CC2.1]
2. This is the Company's only list of approved AI tools. Where another policy refers to approved AI tools, it means this one. [SOC 2: CC5.3, CC2.1]
3. Adding a tool should take days, not weeks. Ask the Accountable Party; where the tool will see nothing above Internal, approval is expected to be immediate. A register that lags is what drives quiet unapproved use, so the speed of this is a control. [SOC 2: CC9.2]
4. Looked at once a year, and when a provider announces a change to its terms or retention. No scheduled re-approval of tools that have not changed. [SOC 2: CC9.2, CC3.4]

8 Using AI Assistants

1. Use approved tools through Company accounts. Do not put Company or client information into free or consumer tiers, where the terms generally permit the provider to train on what is submitted. This is the rule that matters most and the one with no exceptions. [SOC 2: CC6.7 · C1.1]

2. The classification a tool may receive is the one in the register. Restricted information goes to no external model unless the register records a contractual basis for it. [SOC 2: CC6.7 · GDPR Art. 28]
3. Client information is not used to train or fine-tune a model without the client's written agreement. [SOC 2: CC9.2 · GDPR Art. 6, 28]
4. Check what you rely on. Do not present AI output as verified unless you verified it. Nobody is expected to check what they are not relying on. [SOC 2: CC1.1]

9 Model Providers

1. A provider that will see client information is assessed before use: whether submissions are used for training, what retention applies, and whether it becomes a sub-processor. A page is enough. [SOC 2: CC9.2 · GDPR Art. 28]
2. A provider that will see nothing above Internal is recorded in the register and needs no separate assessment. Most tools are this. [SOC 2: CC9.2]
3. Providers handling client information go on the sub-processor list under the Vendor Management Policy, so client notification obligations can be met. [SOC 2: CC9.2 · GDPR Art. 28]
4. Self-hosted models are recorded in the asset inventory with a named owner and where the weights came from. License terms are checked once, at adoption. [SOC 2: CC2.1, CC9.2]

10 Agents and Automation

An agent is the case where a mistake acts rather than merely advises. The limits below are what make that acceptable.

1. Each agent runs under its own identity with the narrowest permissions that let it work, never a person's credentials, and its access is reviewed with everyone else's. [SOC 2: CC6.1, CC6.3]
2. An agent does not approve, merge or deploy a change on its own authority. A named person approves anything that reaches production, and the Change Management Policy governs how. [SOC 2: CC8.1]
3. Agent activity is reconstruct-able: the triggering input, the tools invoked, the parameters, the actions taken and the outcome. How that is recorded and retained is in the Logging Standard. [SOC 2: CC7.2]
4. Every agent has a named owner recorded against their role, and ownership is reassigned during offboarding before that person's access is removed. [SOC 2: CC1.3, CC6.2]
5. An agent that behaves outside its intended scope is stopped first and diagnosed second. Where it may have affected Company or client information, it is handled as an incident under the Incident Response Policy. [SOC 2: CC7.3, CC7.4]

11 Prompts, Models and Configuration

1. Prompts, tool definitions, retrieval configuration and guardrails live in the code repository and change through the normal pull request. They are part of how the system behaves, so they

follow the same path as code — no additional approval step and no separate register. [SOC 2: CC8.1]

2. A model version change is a change like any other. Where a provider moves a version without asking, note it and check the result; there is nothing to approve after the fact. [SOC 2: CC8.1, CC3.4]

12 The Check Before Shipping

This section holds the check referred to elsewhere in this Policy. It applies to changes that widen what a system can reach or do — not to every prompt edit.

1. A check is required where a change gives the system access to data it could not previously reach, adds or widens a tool an agent can call, or puts a model in front of a client for the first time. Ordinary prompt and copy changes do not need one; the pull request review is enough. [SOC 2: CC8.1]
2. Where it applies, the person making the change records three things on the pull request: what data the system can now reach, whether injection and tool-misuse handling still holds for the tools exposed, and whether output on a few representative cases still looks right. A short paragraph. [SOC 2: CC8.1, CC7.1]
3. Where a change cannot usefully be checked before shipping, say what will be watched afterwards and for how long. That is a complete answer. [SOC 2: CC5.3, CC7.2]

13 Keeping Up With the Field

1. Once a year the Accountable Party records what changed that bears on the Company's AI use — provider terms and retention, model deprecations, notable attack techniques against LLM and agent systems, and applicable regulation — and what the Company did about it. A few lines in the annual assessment. [SOC 2: CC3.4, CC2.1]
2. The sources relied on are named in the external information source list under the Information Security Policy, so this is a list someone can check rather than a claim to be paying attention. Six to ten sources is plenty. [SOC 2: CC2.1, CC3.4]
3. Where something changes the Company's risk position, it triggers reassessment under the Risk Management Policy. Where nothing did, record that. [SOC 2: CC3.4]

14 Records

1. The approved AI tool register, with classifications and review dates. [SOC 2: CC9.2, CC2.1]
2. Vendor assessments for model providers, and their entries on the sub-processor list. [SOC 2: CC9.2]
3. Evaluation records attached to AI change records. [SOC 2: CC8.1]
4. The agent inventory with owners, identities and permissions. [SOC 2: CC6.1, CC2.1]
5. The annual AI external-change review entry. [SOC 2: CC3.4]

15 Enforcement

1. A breach is handled under the Code of Conduct, with the finding, the decision and the reason recorded. Client information reaching an unapproved tool is the case most likely to arise; telling someone quickly is treated as cooperation and is what limits the damage. [SOC 2: CC1.1, CC1.5]

16 Exceptions

Where a requirement of this Policy would block legitimate work, an exception is recorded by the Accountable Party with the reason, the compensating measure and a review date, rather than being worked around silently. Where no exceptions are in force, that is recorded affirmatively at the annual review.

17 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.1, CC3.4, CC6.1, CC6.7, CC7.2, CC7.3, CC8.1, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3, CC2.1]
3. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
4. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
5. POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
6. STD-LOG-001 Logging Standard [SOC 2: CC7.2]
7. POL-AC-001 Access Control Policy [SOC 2: CC6.1]
8. POL-AUP-001 Acceptable Use Policy [SOC 2: CC6.7]
9. POL-IRP-001 Incident Response Policy [SOC 2: CC7.3]
10. POL-RSK-001 Risk Management Policy [SOC 2: CC3.4]
11. EU General Data Protection Regulation, Articles 5, 6, 28 and 32

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release